PATRIMONIAL SEGURANÇA LTDA — GOVERNANÇA E GESTÃO DA CADEIA DE SUPRIMENTOS

PROCESSO FORMAL DE AVALIAÇÃO DE TERCEIROS E FORNECEDORES

Código	PSI-PAT-004 (Requisito 8.1)	**Data de Emissão**	06/11/2026
Versão	1.0	**Classificação**	Interna
Aprovação	Comitê de Privacidade, Jurídico e Diretoria	**Base Normativa**	LGPD, Res. CMN nº 4.893/2021 (Arts. 12 e 17) e ISO/IEC 27001:2022

1. Objetivo e Vedação de Contratação Informal

Instituir a metodologia obrigatória de diligência prévia (*due diligence*), homologação e monitoramento contínuo de fornecedores e prestadores de serviços que tratem dados pessoais, forneçam soluções em nuvem ou tenham acesso lógico/físico à infraestrutura da Patrimonial Segurança LTDA. Fica expressamente vedada a contratação de fornecedores tecnológicos ou de tratamento de dados baseada exclusivamente em indicação comercial sem o cumprimento integral deste processo.

2. Matriz de Classificação de Risco de Terceiros

Antes da contratação ou renovação contratual, o setor solicitante, em conjunto com a TI e o Setor Jurídico, deve enquadrar o fornecedor em um dos três níveis abaixo:

Nível de Risco	Perfil do Fornecedor / Escopo de Atuação	Exigências de Homologação
Nível 1 – Crítico	Provedores de nuvem e data center, softwares de monitoramento (Segware), ERP (Sankhya), links dedicados, segurança de rede e consultorias com acesso a dados Confidenciais ou Restritos.	Checklist completo de segurança, comprovação de certificações (ISO 27001/27701 para nuvem/data center), parecer de TI/DPO, contrato com DPA, NDA e cláusulas CMN nº 4.893.
Nível 2 – Moderado	Prestadores de serviços técnicos ou administrativos com acesso pontual e supervisionado à rede interna ou a dados cadastrais básicos.	Questionário simplificado de conformidade, acesso restrito via VPN com MFA, assinatura obrigatória de NDA e cláusula de proteção de dados (LGPD).
Nível 3 – Baixo	Fornecedores de suprimentos gerais ou serviços prediais sem qualquer acesso à rede lógica, sistemas ou dados pessoais sob custódia.	Cadastro comercial padrão no ERP Sankhya e cláusula contratual padrão de confidencialidade.

3. Etapas Obrigatórias do Fluxo de Homologação (Due Diligence)

1. **Aplicação do Questionário de Conformidade:** O fornecedor de Nível 1 ou 2 deve responder ao questionário técnico da Patrimonial Segurança, evidenciando controles de acesso, criptografia, backup, continuidade de negócios e indicação de DPO.
2. **Transferência de Risco e Certificações:** Em cumprimento à Matriz de Riscos corporativa, exige-se contratualmente que os principais fornecedores de nuvem e data center possuam certificações ISO/IEC 27001 e/ou ISO/IEC 27701 vigentes.
3. **Parecer Técnico e de Privacidade:** A Coordenação de TI e os DPOs externos avaliam as evidências, emitindo parecer de aprovação, aprovação condicional com plano de ação ou reprovação.
4. **Formalização Contratual e Acordo de Processamento de Dados (DPA):** O Setor Jurídico integra ao contrato o DPA padronizado, cláusulas de responsabilização financeira (multas por descumprimento de segurança) e os requisitos do art. 17 da Resolução CMN nº 4.893/2021 (segregação de dados, notificação de incidentes e exclusão segura ao término da relação).

4. Monitoramento Anual e Fornecedores de Contingência

> **Avaliação Periódica e Continuidade (Requisito 11.4):** Os fornecedores de Nível 1 (Crítico) são reavaliados anualmente pelo Comitê de Privacidade. Para serviços essenciais à operação de monitoramento 24/7, a empresa mantém fornecedores e prestadores alternativos mapeados (contingência), evitando dependência exclusiva de um único fornecedor.

Setor Jurídico e Coordenação de TI Homologação Técnica e Contratual	**Diretoria Executiva — Patrimonial Segurança LTDA** Aprovação e Homologação Institucional